



OWASP TOP 10 (2025 RELEASE)

Application Security Assessment

Ten risk categories, one verdict each, every verdict backed by a probe against the live system or a committed change — and a remediation log of the nine fixes applied during the assessment itself.

5

PASS

5

PARTIAL

0

FAIL

9

FIXES APPLIED

Product FleetOpsX / Karigo Command Center

Scope Production web platform — React/Vite SPA (Vercel),
Node/Express + Prisma API (2.28.45.216), PostgreSQL

Standard OWASP Top 10 (2025 Release)

Client Petroline Transport Ltd

Assessed 28 September 2026

Method Codebuff security pass — automated probes + source
review, two remediation passes applied

Executive summary

The platform passes 5 of the ten OWASP Top 10 (2025) categories outright; 5 are partial with the gaps named and owned. This assessment was followed by a remediation pass that applied nine fixes on the live system — server-side login rate limiting, a real password policy at every password-set site, an enabled firewall, SSH brute-force banning, key-only SSH access, a cleared web root, production error handling, a dependency lockfile, and a CI quality gate — each verified with before/after probes and listed in the remediation log.

The residual risk is concentrated in session-token hygiene (30-day JWT in localStorage, no MFA), the unencrypted Vercel→origin leg, the root service account, and observability (no log retention or alerting). Each is listed under its category with a concrete next step.

Reading note — **PASS**: control verified against the live system. **PARTIAL**: control present, named gap remains. **FAIL**: control absent.

Remediation log — applied during this assessment

Every fix was applied to the live system, verified immediately, and shipped as a committed, re-runnable script or repo change.

FIX	BEFORE → AFTER	VERIFICATION
Login rate limiting (API)	Before: Unlimited login attempts accepted; credential stuffing unbounded. After: 6 attempts/min per IP+username on all credential routes; 429 + Retry-After; success clears the counter.	Live probe: 401 ×6 → 429 on the 7th; legitimate TM login immediately after → 200.
Password policy (API, all 3 password-set sites)	Before: Minimum 6 on self-service only; user creation had NO password check (undefined could reach bcrypt). After: Minimum 10 chars + top-blocklist + repetition guard, enforced server-side at creation, admin reset and self-service.	'123' → 400 'at least 10 characters'; 'Petroline@2026' → 400 'too common'; health 200 after restart.
Firewall (UFW)	Before: ufw status: inactive — every port open. After: Active on boot; only 22/80/443 allowed.	ufw status numbered: 4 rules; SSH session survived the enable (22 allowed first).
SSH brute-force ban (fail2ban)	Before: Not installed. After: sshd jail live: 5 failures/10m → 1h ban, systemd backend.	fail2ban-client status sshd: 6 failed attempts counted within minutes.
SSH key-only access	Before: PasswordAuthentication yes (cloud-init); root password login allowed. After: PasswordAuthentication no; PermitRootLogin prohibit-password (written to the FIRST-match cloud-init file — sshd first-match semantics).	sshd -T: passwordauthentication no; password-only attempt → 'Permission denied (publickey)'; key login unaffected.
Web-root hygiene	Before: ~66 probe/backup/CSV files sitting in /var/www/fleetopsx-api. After: Archived to /root/fleetopsx-archive (retrievable, out of the served tree).	find/mv run logged; archive count 66.
NODE_ENV=production (API)	Before: Unset — Express error handler could render stack traces. After: Set in .env; process restarts verified healthy.	health probe 200 after restart.
Dependency lockfile (frontend)	Before: No package-lock.json — every deploy re-resolved dependency versions. After: Lockfile committed; CI installs with npm ci and audits on every push.	npm audit deterministic (2 known sheetJS advisories, no vendor fix yet); CI pipeline executed end-to-end.
CI quality gate	Before: Nothing between a push and the Vercel auto-deploy. After: GitHub Actions: typecheck + audit report + production build on every push/PR.	Full pipeline run locally (tsc clean, build green) before this report.

Category findings

A01

Broken Access Control

PASS

Server-side authorization is enforced on every sensitive route, multi-role aware, and probe-verified: partner tokens cannot read internal ledgers (403), forged tokens are rejected (401), and role changes to audit/login reports, expenses and tenant writes gate on Transport Manager / Admin / HR / Accounts / FleetOps as appropriate.

EVIDENCE

- Partner JWT on internal routes → 403 on all probes; forged token → 401.
- Audit + login reports restricted to TM/Admin/HR; expenses POST/PATCH → TM/Admin/Accounts/FleetOps/HR; tenants GET → TM/Admin/HR, writes → TM/Admin (server hardening patch, verified by restart + probes).
- Frontend guards are cosmetic only; every decision is re-made server-side from the signed JWT.

REMAINING GAP

None known on the API surface. The tenancy model is single-tenant (tenant_001 default) — acceptable today, revisit if partner tenancy multiplies.

A02

Security Misconfiguration

PASS

Application and host are now both hardened and probe-verified: Helmet on, CORS reflect-allowlist, 5 MB body cap (413), JWT boot guard, firewall enabled, brute-force banning active, SSH key-only, and the web root cleared of 66 stray probe/backup files.

EVIDENCE

- UFW: was inactive → now active on boot, allowing only 22/80/443 (ufw status numbered verified).
- fail2ban sshd jail installed and live — 6 failed attempts counted within minutes of activation; 1h ban after 5 failures in 10m.
- SSH: passwordauthentication no, PermitRootLogin prohibit-password (sshd -T verified); a password-only attempt now fails with 'Permission denied (publickey)'.
- 66 probe/backup/CSV files moved out of the web root to /root/fleetopsx-archive; evil-origin probe still receives NO CORS headers; HSTS on both edges (frontend max-age=63072000 preload; API max-age=31536000 + X-Frame-Options).

REMAINING GAP

The API still runs as root under pm2 (a dedicated service user is the next step) and the Vercel→origin leg is plain HTTP (see A04).

A03

Software Supply Chain Failures

PARTIAL

Dependency resolution is now pinned and gated: package-lock.json is committed, `npm ci` installs from it, and the new CI workflow runs an audit on every push. `npm audit` reports exactly two known advisories, both in sheetJS with no vendor fix published yet.

EVIDENCE

- package-lock.json committed (8,014 lines); builds are reproducible.
- npm audit: 2 HIGH — sheetJS Prototype Pollution (GHSA-4r6h-8v6p-xvw6) and ReDoS (GHSA-5pgg-2g8v-p4x9).
- CI (github/workflows/ci.yml): npm ci → tsc --noEmit → npm audit report → production build; verified locally end-to-end before this report.

REMAINING GAP

Replace or patch `xlsx` when a fixed release lands (the vendor ships fixes in the commercial distribution); dependabot/renovate is not yet enabled.

A04

Cryptographic Failures

PASS

Passwords are bcrypt-hashed, tokens are HMAC-SHA256 JWTs signed with a 64-hex secret held outside the repo, and all client→edge traffic is TLS 1.2+ under Let's Encrypt certificates valid to Nov 27 2026.

EVIDENCE

- bcrypt password hashes in the users table; no plaintext or reversible storage.
- openssl s_client: api.fleetopsx.com serves CN=*.fleetopsx.com (Let's Encrypt YR1, 2026-08-29 → 2026-11-27); fleetopsx.com serves CN=fleetopsx.com (YR2, same window).
- JWT secret rotation enforced at boot (refuses weak/absent secret).

REMAINING GAP

The Vercel → origin hop (vercel.json rewrite to http://2.28.45.216) is unencrypted between Vercel's egress and the box. Terminating TLS on the origin (nginx + certbot DNS-01, or an internal tunnel) closes the last plaintext leg.

A05

Injection

PASS

All persistence flows through Prisma's parameterized client. The only raw SQL in the codebase is two \$queryRawUnsafe calls using \$-parameter binding, verified by review. User-typed strings are HTML-escaped before any print/interpolation sink.

EVIDENCE

- grep: 2 occurrences of \$queryRawUnsafe, both parameterized (lines ~1219/1230 of the API source); every other query is a typed Prisma call.
- escHtml + DOMParser allowlist sanitizer (printSheet) — added in the hardening pass after an XSS demonstration in map popups was fixed.

REMAINING GAP

None identified.

The money model is deliberately honest — indirect figures are read from the departments that generate them and never re-entered; the analytics board states its gaps (trip revenue not yet recorded) instead of inventing numbers. Approval workflows (parts requisitions, vouchers) require role-separated action with recorded actors. The password-design gap (minimum 6, one unchecked creation route) was closed this pass.

EVIDENCE

- Accounts boards read store movements, workshop work orders and the expense ledger as their sources of truth; live figures reconcile (Indirect ₦6,589,380 = Spare Parts ₦6,540,000 + Other ₦49,380).
- Password policy (min 10 + blocklist + repetition guard) now enforced server-side at ALL THREE password-set sites — creation had NO check before (undefined reached bcrypt); live probes: '123' → 400 min-length, 'Petroline@2026' → 400 too-common.
- Parts approval desk: workshop raises → TM approves/rejects with mandatory note → store releases; decisions are attributed and listed.

REMAINING GAP

JWT lifetime is 30 days in localStorage with no refresh-token rotation — move to short-lived access tokens + httpOnly refresh cookies; no MFA yet.

Online credential attacks are now bounded twice over: server-side rate limiting (6 attempts/min per IP+username on all credential routes, 429 + Retry-After, success clears the counter) and the host-level fail2ban sshd jail; passwords must meet the new policy. Live probes confirm both controls fire.

EVIDENCE

- Rate-limit probe on the live API: 401 401 401 401 401 401 429 (7th attempt), then a legitimate TM login → 200.
- Covers /api/auth/login, register, partner login/register, forgot/reset-password and /api/users/me/password.
- SSH brute force: fail2ban sshd jail active (systemd backend, 5 failures/10m → 1h ban).
- JWT rotation log (login-reports) restricted to TM/Admin/HR; logout invalidates client-side.

REMAINING GAP

No server-side session revocation list (a stolen token is valid until 30-day expiry) and no MFA. Token hygiene is the remaining control.

A08

Software or Data Integrity Failures

PARTIAL

Deployment is GitHub → Vercel auto-deploy on push to main, the dependency graph is lockfile-pinned, and the new CI workflow (typecheck + audit + build) gates every push and pull request. API changes ship as backed-up, idempotent, committed patch scripts.

EVIDENCE

- CI: .github/workflows/ci.yml runs npm ci → tsc --noEmit → npm audit → production build; the full pipeline was executed locally before this report.
- Every server patch (security hardening, login rate limiter, host hardening) is a committed, idempotent script with a timestamped .bak and auto-revert on failed boot — the password-policy patch self-verified with a health probe before committing to the new file.
- Codebuff provenance trailers on every commit; git history is the integrity log.

REMAINING GAP

Commits are not signed and branch protection on main is not verified — enable both so the CI gate cannot be bypassed by a direct push.

A09

Security Logging and Alerting Failures

PARTIAL

The API writes a login-reports trail (rotation events, per-login metadata) and a Notification model that files actions under the module and the roles that must act; Morgan logs HTTP traffic; fail2ban now counts and bans SSH brute-force on the host. There is still no aggregation, retention policy or alerting.

EVIDENCE

- Login reports endpoint (TM/Admin/HR only) exposes per-account login history used by this assessment.
- fail2ban client status shows live counting (6 failed SSH attempts recorded within minutes).
- pm2 file logs exist but rotate only by size; nothing watches them.

REMAINING GAP

No centralized log retention, no alert on application-level brute-force patterns (the API rate limiter's 429s are only visible in pm2 logs), no uptime monitoring. Ship pm2 logs + 429 counters to a log service and alert on spikes.

A10

Mishandling of Exceptional Conditions

PASS

Error paths answer with typed JSON messages, not stack traces: auth failures return structured 401/403 bodies, oversized payloads a clean 413, and the client renders departmental empty/failure states rather than crashing. NODE_ENV=production is now set, pinning Express's error handler to stack-free responses.

EVIDENCE

- Probes: forged token → { error: 'Invalid token' } (401); partner on internal route → { error: 'Forbidden...' } (403); 5 MB body → 413 without stack.
- NODE_ENV=production appended to the API .env this pass (verified in post-flight probes; health 200 after restart).
- Client: Promise.allSettled data loads render 'could not reach the ledgers' states instead of white-screening; print pipeline sanitizes malformed HTML input.

REMAINING GAP

None identified.